B3-Act12-TP1 – Auditer l'Active Directory (4h)

Active Directory est un **annuaire d'entreprise** utilisé pour stocker des informations sur les ressources informatiques, telles que les ordinateurs, les utilisateurs, les groupes et les autorisations.

L'audit d'un AD est important pour maintenir la sécurité et la conformité de l'environnement informatique. Les administrateurs système et les équipes de sécurité doivent surveiller l'activité de l'AD pour détecter toute activité malveillante, comme une tentative de piratage, une modification non autorisée des autorisations ou des accès, ou encore la création de nouveaux comptes d'utilisateurs frauduleux.

Les outils d'audit de l'AD peuvent aider à surveiller les journaux d'audit et les événements de sécurité pour détecter les activités suspectes, les anomalies ou les tendances qui pourraient indiquer une faille de sécurité ou une violation de la politique de sécurité. Les rapports d'audit peuvent aider à identifier les risques de sécurité, à suivre les modifications apportées aux comptes d'utilisateurs et aux autorisations, et à évaluer la conformité réglementaire de l'environnement informatique.

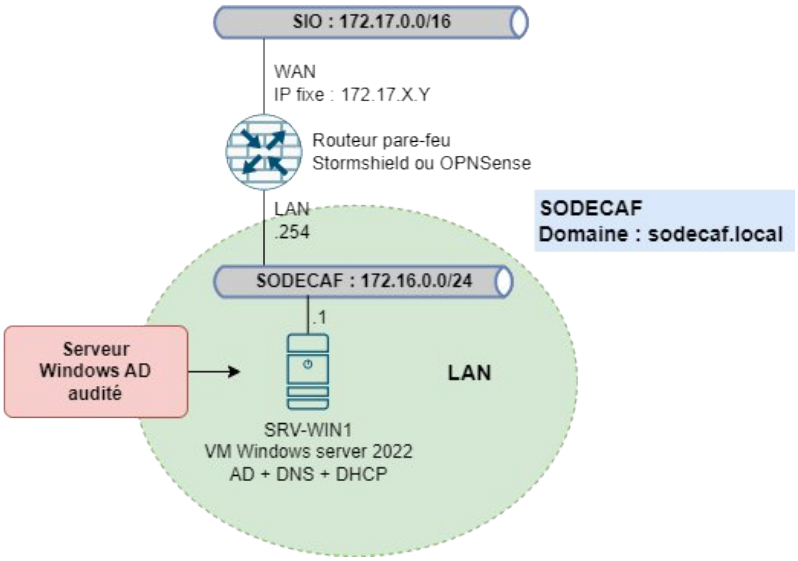
Vous êtes membre du service SI de la SODECAF et **votre DSI vous demande de faire un audit de votre serveur AD**. Pour cela, vous allez utiliser les logiciels **PingCastle et Specops Password Auditor**.

PingCastle est un logiciel français bien connu par les entreprises du secteur de la **cybersécurité**. L'utilisation de PingCastle est gratuite tant que vous l'utilisez pour auditer votre propre annuaire Active Directory. Par contre, si vous utilisez PingCastle pour auditer l'annuaire d'un client dans le cadre d'une prestation, vous devez acquérir une licence.

Les mots de passe Active Directory des utilisateurs sont aussi un point faible bien connu des hackers. Specops propose un outil d'audit gratuit et précieux pour renforcer la sécurité de l'AD en matière de mots de passe : **Specops Password Auditor vérifie les hashes de mots de passe** ayant fait l'objet d'une fuite publique et génère plusieurs rapports interactifs contenant des informations sur les utilisateurs et les politiques de mots de passe.

Contexte de travail

Nous travaillons sur le contexte de la SODECAF, avec l'infrastructure montée précédemment sous VirtualBox. Votre objectif est d'effectuer un audit de sécurité de votre serveur Active Directory.



Pour des raisons de simplicité, nous installerons et utiliserons les logiciels PingCastle et SpecopsPasswordAuditor directement sur le serveur Active Directory. Nous travaillerons toutefois avec un clone du serveur qui est en production. Une VM routeur pare-feu peut être nécessaire pour un accès à internet.

Travail à réaliser

Partie A : Audit général du serveur AD

- Clonez votre serveur SRV-WIN1 (un clone lié suffit). Nous travaillerons avec ce clone.
- Sur le serveur SRV-WIN1, téléchargez PingCastle à l'adresse https://www.pingcastle.com/download/ et procédez à son installation.
- Suivez le tutoriel à l'adresse https://www.it-connect.fr/comment-auditer-lactive-directory-avec-pingcastle/ pour effectuer un premier audit du serveur Active Directory de la Sodecaf. Les fichiers de ce premier audit sont ad_hc_sodecaf.local.html et ad_hc_sodecaf.local.xml. Ouvrez le fichier html avec un navigateur web. **Plus la note est élevée, plus votre serveur AD est vulnérable.**

  Remarque : la note globale sur 100 correspond à la note maximale obtenue parmi les 4 critères évalués.

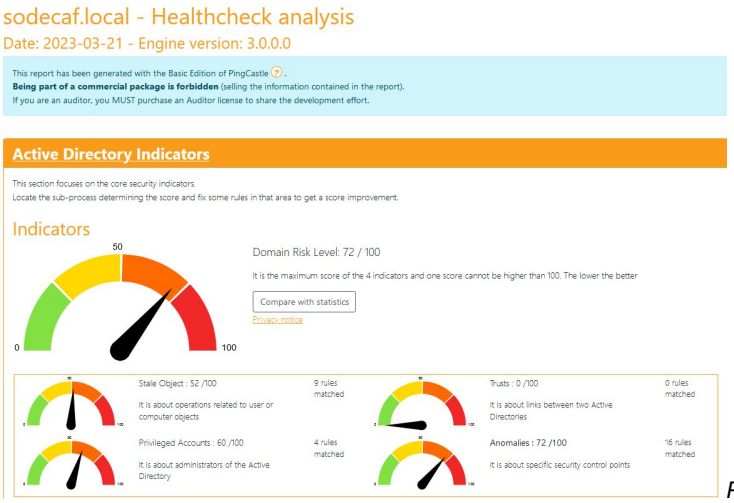
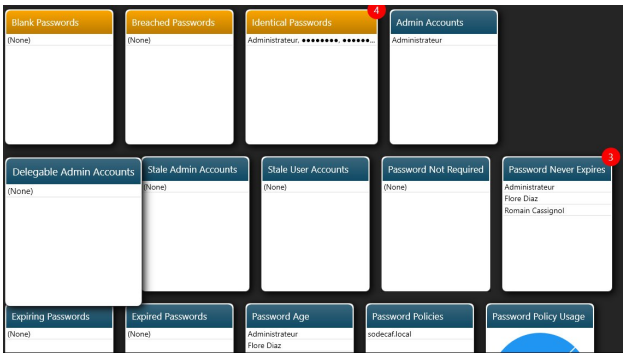


Figure1: Exemple de rapport obtenu

- Sauvegardez les deux fichiers de ce premier rapport.
- Proposez des mesures permettant d'abaisser la note globale sous 25 points (couleur verte). Documentez votre travail (page suivante) en indiquant pour chaque vulnérabilité détectée la contre-mesure mise en place. Vous pouvez vous aider des préconisations de l'ANSSI à l'adresse https://www.cert.ssi.gouv.fr/uploads/guide-ad.html.
- Sauvegardez les deux fichiers du nouveau rapport.

Partie B : Audit des mots de passe

- Sur le serveur, téléchargez Specops Password Auditor à l'adresse https://specopssoft.com/specops-password-auditor-update/ et exécutez le fichier SpecopsPasswordAuditor.
- Lancez le logiciel installé, choisissez un dossier pour le téléchargement de bases de données de mots de passe. L'audit démarre.



- Sauvegardez cet audit au format pdf.
- Proposez des solutions afin de supprimer quelques vulnérabilités sur les mots de passe.
- Documentez votre travail (page suivante) en indiquant pour chaque vulnérabilité détectée la contre-mesure mise en place.
- Envoyez votre travail à votre enseignant.

Partie A : Audit général du serveur AD

Vulnérabilités	Contre-mesures	Points	Difficulté

Partie B : Audit des mots de passe

Vulnérabilités	Contre-mesures	Difficulté